

积木仓 BlockHub 信息安全白皮书

企业评估版 · 数据驻留 · 传输与静态加密 · 访问控制 · 删除承诺

对外可控分发 · 供采购 / 安全 / 合规评估 · 版本 2026-07-16

置信度说明：本白皮书基于积木仓 BlockHub 当前产品设计及安全控制措施编写，适用于企业级采购、安全与合规评估。文中指标均以试点或合同约定为准，不构成绝对安全承诺。置信度适用于境内部署场景，境外部署需另行评估。

1. 文档目的、读者与置信度边界

本白皮书旨在向企业信息安全、合规、采购及架构负责人提供积木仓 BlockHub 产品在数据驻留、加密、访问控制、删除等方面的安全控制说明。文档基于产品当前设计及默认配置编写，供评估方参考，不构成合同条款。

读者对象包括：企业安全架构师、合规经理、采购专员、法务顾问及技术评估人员。建议读者具备基础信息安全知识，理解 PaaS 平台常见风险。

置信度边界：本白皮书描述的控制措施在积木仓 BlockHub 标准版本中默认启用，但具体实现可能因客户定制或部署环境而异。所有指标（如加密算法、密钥长度、审计日志保留期）均以试点测试或最终合同为准。

文档中提及的“默认境内”指数据默认存储于中国大陆境内节点，客户可要求指定区域，但需在合同中明确。空库空列表指产品初始状态无客户数据，所有数据由客户创建。

本白皮书不涵盖客户自行开发的应用程序安全，也不替代客户自身的合规义务。客户应结合自身安全策略进行独立评估。

积木仓 BlockHub 为“选型即交付”产品，即客户选定后直接使用，无需额外开发。Web 端与 App 端共享同一安全契约，确保一致性。

2. 产品安全架构总览

积木仓 BlockHub 采用多层安全架构，涵盖网络、主机、应用、数据及管理层面。所有组件部署于虚拟私有云（VPC）内，通过安全组和网络 ACL 限制流量。

网络层：所有公网入口均通过负载均衡器，并启用 Web 应用防火墙（WAF）过滤常见攻击。内部服务间通信采用 TLS 1.2+ 加密，证书由内部 CA 签发。

主机层：计算节点使用最小化操作系统镜像，定期扫描漏洞并自动修补。主机入侵检测系统（HIDS）监控异常行为，日志集中存储。

应用层：代码经过静态分析、动态扫描及人工代码审查。API 接口强制身份认证，并实施速率限制防滥用。会话管理使用 HttpOnly、Secure 标志的 Cookie。

数据层：所有数据库、对象存储及缓存均启用静态加密。密钥由硬件安全模块（HSM）或云密钥管理服务（KMS）保护，密钥轮换周期可配置。

管理层：运维人员通过堡垒机访问生产环境，操作全程审计。权限遵循最小权限原则，多因素认证（MFA）强制启用。

3. 数据驻留、分类与出境控制

积木仓 BlockHub 默认将客户数据存储于中国大陆境内的数据中心。客户可在合同中指定其他区域，但需确认该区域是否满足合规要求。数据驻留选项包括：境内、香港、新加坡等，具体以合同为准。

数据分类：客户数据分为账户信息、业务数据、日志数据及配置数据。账户信息包括邮箱、手机号等；业务数据为客户通过平台创建的内容；日志数据包括操作审计和访问日志；配置数据为平台设置。

出境控制：默认禁止数据出境。若客户选择境外节点，则数据存储于该节点所在区域，不跨境传输。跨境传输仅在客户明确授权且符合当地法规时进行，例如客户主动调用境外 API。

数据隔离：每个客户的数据在逻辑上通过租户 ID 隔离，物理上使用独立数据库实例或 schema。对象存储使用客户专属前缀，避免跨租户访问。

客户可自行导出数据，平台提供 API 和 Web 界面下载。导出格式为 JSON 或 CSV，导出操作记录在审计日志中。

空库空列表：产品初始状态不包含任何客户数据，所有数据由客户创建。客户可随时删除数据，删除操作不可逆。

4. 传输安全、静态加密与密钥管理

传输安全：所有公网通信强制使用 TLS 1.2 或更高版本，证书由公共 CA 签发。内部服务间通信使用 mTLS，证书由内部 CA 管理，有效期 1 年。

静态加密：所有持久化数据（数据库、对象存储、备份）均使用 AES-256 加密。数据库表空间加密，对象存储使用服务器端加密（SSE）。

密钥管理：加密密钥由云 KMS 或 HSM 保护，密钥层次分为主密钥和数据密钥。主密钥由客户或平台管理（取决于配置），数据密钥定期轮换（默认 90 天）。

客户可自带密钥（BYOK）用于部分服务，需在合同中约定。平台不存储客户明文密钥，密钥使用记录可审计。

备份数据同样加密，备份存储于异地，加密密钥与生产环境分离。恢复时需双重授权。

密钥销毁：当客户删除数据或终止服务时，相关密钥将被标记为删除，并在 30 天后物理销毁。销毁过程记录日志。

5. 身份认证、RBAC 与多租户隔离

身份认证：用户登录支持密码、短信验证码及第三方 OAuth（如企业微信、钉钉）。密码策略要求至少 8 位，包含大小写字母和数字，可配置复杂度。

多因素认证（MFA）：管理员账户强制启用 MFA，普通用户可选。MFA 方式包括 TOTP 和短信验证码。

RBAC：平台内置角色包括超级管理员、管理员、开发者、审计员、只读用户。每个角色拥有预定义权限集，客户可自定义角色。权限粒度到 API 和页面级别。

多租户隔离：租户间数据通过租户 ID 严格隔离，应用层和数据库层均实施访问控制。一个租户的用户无法访问另一租户的数据。

会话管理：会话令牌使用 JWT，有效期可配置（默认 24 小时）。令牌包含租户 ID 和角色信息，服务端验证签名。

登录失败锁定：连续 5 次登录失败后，账户锁定 15 分钟。锁定策略可配置。

6. 开发运维安全与变更管理

开发安全：所有代码提交前需通过静态安全扫描（SAST），并执行依赖项漏洞检查。关键模块需通过人工代码审查。

变更管理：生产环境变更需提交变更请求，经安全团队和架构师审批。变更窗口为工作日上午，紧急变更需单独授权。

CI/CD 管道：代码从开发到生产经过开发、测试、预发布、生产四个环境。每个环境独立部署，流水线中集成安全扫描（DAST、容器扫描）。

配置管理：敏感配置（密码、密钥）存储在专用密钥管理服务中，不写入代码仓库。配置变更需审批并记录。

漏洞管理：平台定期进行漏洞扫描（每周）和渗透测试（每季度）。严重漏洞在 24 小时内修复，高危漏洞在 7 天内修复。

应急响应：安全事件响应流程包括检测、分析、遏制、根除、恢复、总结。SLA 为：严重事件 1 小时内响应，4 小时内遏制。

7. 审计日志、留存与事件响应

审计日志：记录所有用户操作、管理员操作、API 调用及系统事件。日志字段包括时间戳、用户 ID、操作类型、资源、结果、源 IP。

日志留存：操作日志保留 180 天，访问日志保留 90 天，系统日志保留 30 天。客户可要求延长留存期，需在合同中约定。

日志保护：日志写入后不可修改，存储于独立日志系统，访问权限受限。日志传输使用 TLS，存储加密。

事件响应：安全事件分类为严重、高、中、低四级。严重事件包括数据泄露、服务中断；高级事件包括未授权访问、恶意软件。

响应流程：发现事件后，安全团队立即启动调查，通知客户（如涉及客户数据）。严重事件在 1 小时内通知，高级事件在 4 小时内通知。

事后总结：事件解决后 7 天内提供根本原因分析报告，并实施改进措施。客户可索取报告摘要。

8. 第三方与子处理器管控

积木仓 BlockHub 使用第三方服务包括：云基础设施提供商（如阿里云、腾讯云）、CDN 服务、短信服务、邮件服务。所有第三方均经过安全评估。

子处理器列表：当前子处理器包括阿里云（计算、存储）、腾讯云（部分节点）、SendCloud（邮件）、阿里云短信。列表随合同更新。

管控措施：与第三方签订数据保护协议（DPA），明确数据使用限制。定期审查第三方安全认证（如 ISO 27001、SOC 2）。

数据共享：仅共享必要数据（如 IP 地址、邮箱），不共享业务数据。第三方不得将数据用于自身目的。

变更通知：新增或更换子处理器时，提前 30 天通知客户。客户有权拒绝并终止服务。

审计权：客户可要求查看第三方安全认证或审计报告，但需签署保密协议。

9. 删除、退出与客户可索取证据

数据删除：客户可通过平台界面或 API 删除数据。删除操作立即生效，数据标记为删除，并在 30 天内物理清除。

账户退出：客户可随时终止服务，终止后数据保留 90 天（宽限期），之后永久删除。宽限期内客户可导出数据。

删除确认：数据删除后，平台提供删除证明（日志截图或报告）。客户可索取，平台在 7 个工作日内提供。

可索取证据：客户可索取安全认证（ISO 27001、SOC 2 报告）、渗透测试报告摘要、审计日志导出（需在合同约定范围内）。

证据提供：所有证据需签署保密协议，平台在 15 个工作日内提供。部分证据可能涉及第三方，需额外时间。

退出流程：客户提交退出申请后，平台协助数据导出，确认无数据残留后关闭账户。整个过程不超过 30 天。

10. 附录：安全控制对照清单

以下清单对照常见安全框架（ISO 27001、SOC 2、等保 2.0）的控制项，供评估参考。具体符合性以认证报告为准。

- A. 数据加密：传输 TLS 1.2+，静态 AES-256，密钥轮换 90 天。
- B. 访问控制：RBAC、MFA、会话超时、登录锁定。
- C. 审计日志：操作日志 180 天，访问日志 90 天，不可篡改。
- D. 漏洞管理：每周扫描，每季度渗透测试，修复 SLA。
- E. 事件响应：分级响应，严重事件 1 小时通知。
- F. 第三方管理：DPA、安全审查、变更通知。
- G. 数据删除：30 天物理清除，提供删除证明。
- H. 备份与恢复：每日备份，异地存储，加密，恢复测试每季度。
- I. 物理安全：依赖云提供商，数据中心 SOC 2 认证。
- J. 合规：支持等保 2.0 二级，ISO 27001 认证中。

获取盖章版 / 完整问卷 / 定制差距分析

访问 blockhub.club 信任与合规中心，或预约演示联系客户成功经理。请随附本 PDF 文档编号以便版本核对。